

PRODUCT SECURITY NOTICE

Date: September 24, 2025

Severity: Informational

Reference: PSN-2025-002

Subject: NPM Supply Chain Attack - Qix User Account Compromise

Executive Summary

This notice addresses the NPM supply chain attack that occurred on September 8, 2025, which compromised the Qix user account through a sophisticated phishing campaign. The attack resulted in the injection of cryptocurrency-stealing malware into 18+ popular JavaScript packages including chalk and debug, affecting over 2.6 billion weekly downloads. We are providing this advisory to inform stakeholders about our product's security posture regarding this incident.

Attack Overview

On September 8, 2025, the JavaScript ecosystem experienced what is considered the largest supply chain attack in NPM history. A sophisticated phishing campaign led to the compromise of maintainer Josh Junon's (Qix-) NPM account, resulting in the injection of cryptocurrency-stealing malware into 18+ foundational NPM packages.

- **Attack Vector:** Phishing email impersonating NPM support
- **Timeline:** September 5-9, 2025 (Domain registered Sept 5, attack executed Sept 8)
- **Exposure Duration:** Approximately 2 hours before detection and removal
- **Compromise Method:** Social engineering via fake npmjs.help domain
- **Target:** Browser-based cryptocurrency wallet transactions

Product Impact Assessment

Our product is NOT affected by this attack.

After conducting a comprehensive security review of our dependencies and software supply chain, we have confirmed that our product does not utilize any of the compromised packages associated with the Qix account compromise.

Confirmed Non-Usage of Affected Packages

The following packages are **NOT** used in our product:

Core Libraries: - @coveops/abi@2.0.1 - @duckdb/duckdb-wasm@1.29.2 - @duckdb/node-api@1.3.3 - @duckdb/node-bindings@1.3.3 - duckdb@1.3.3

Color and Styling Libraries: - ansi-regex@6.2.1 - ansi-styles@6.2.2 - chalk-template@1.1.1 - chalk@5.6.1 - color-convert@3.1.1 - color-name@2.0.1 - color-string@2.1.1 - color@5.0.1 - has-ansi@6.0.1 - simple-swizzle@0.2.3 - slice-ansi@7.1.1 - strip-ansi@7.1.1 - supports-color@10.2.1 - supports-hyperlinks@4.1.1 - wrap-ansi@9.0.1

Utility and Debug Libraries: - backslash@0.2.1 - debug@4.4.2 - error-ex@1.3.3 - is-arrayish@0.3.3

Advertising and Web Components: - prebid-universal-creative@1.17.3 - prebid.js@10.9.2 - prebid@10.9.1 - prebid@10.9.2 - proto-tinker-wc@0.1.87

Security Measures Implemented

- Complete dependency audit performed
- Supply chain integrity verification completed
- No compromised packages detected in our codebase
- Continuous monitoring of NPM security advisories active
- Package lock files reviewed for integrity
- Build pipeline security validated

Technical Analysis

The attack employed sophisticated registry-only poisoning, where attackers published malicious code directly to NPM without modifying GitHub repositories. This technique exploited the gap between source repositories and package registries, evading many automated security tools.

Attack Methodology: - **Phishing Infrastructure:** Attackers registered npmjs.help on September 5, 2025, resolving to IP 185.7.81.108 - **Social Engineering:** Sent convincing phishing emails claiming 2FA credentials needed updating before September 10 deadline - **Credential Theft:** Used Bunny-CDN buckets (static-mw-host.b-cdn.net, img-data-backup.b-cdn.net) to host credential-stealing scripts - **Account Takeover:** Within 16 minutes of credential compromise, began publishing malicious package versions

Malware Technical Details: - **Browser-Only Execution:** Code checked for `typeof window !== "undefined" && typeof window.ethereum !== "undefined"` before executing - **API Hooking:** Intercepted `fetch()`, `XMLHttpRequest`, and `window.ethereum.request()` functions - **Cryptocurrency Theft:** Used Levenshtein distance algorithm to substitute legitimate wallet addresses with visually similar attacker-controlled addresses - **Multi-Chain Support:** Targeted Ethereum, Bitcoin, Solana, Tron, Litecoin, and Bitcoin Cash transactions

Compromised Packages (18+ total): - debug@4.4.2 (357M+ weekly downloads) - chalk@5.6.1 (300M+ weekly downloads) - ansi-styles@6.2.2 (371M+ weekly downloads) - supports-color@10.2.1, strip-ansi@7.1.1, wrap-ansi@9.0.1 -

color-convert@3.1.1, color-name@2.0.1, ansi-regex@6.2.1 - Plus additional utility libraries (slice-ansi, has-ansi, error-ex, etc.)

Total Impact: 2.6+ billion combined weekly downloads across all affected packages

Indicators of Compromise

Network Infrastructure: - Domain: `npmjs.help` (phishing domain, no longer accessible) - IP Address: `185.7.81.108` (npmjs.help resolution) - CDN Resources: `static-mw-host.b-cdn.net`, `img-data-backup.b-cdn.net` - Data Exfiltration: `websocket-api2.publicvm.com`

Code Signatures: - Obfuscated JavaScript patterns starting with `const _0x112fa8=_0x180f;` - Variable names: `stealthProxyControl`, `runmask`, `checkethereumw` - Function selectors: `0x095ea7b3` (ERC-20 approve), `0xd505acbf` (permit) - Detection errors: `ReferenceError: fetch is not defined` in Node.js environments

Cryptocurrency Addresses (Primary Ethereum): - `0xFc4a4858bafef54D1b1d7697bfb5c52F4c166976`
- Plus 280+ hardcoded addresses across multiple blockchains

Timeline: - September 5, 2025: Attackers register `npmjs.help` domain - September 8, 2025, 13:00 UTC: Phishing email sent to Josh Junon - September 8, 2025, 13:16 UTC: First malicious packages published
- September 8, 2025, 13:21 UTC: Aikido Security detects attack (5 minutes after)
- September 8, 2025, 15:15 UTC: Josh Junon publicly acknowledges compromise
- September 8, 2025, Evening: NPM removes all malicious versions

Recommendations for Users

While our product remains unaffected, we recommend that all users and development teams:

1. **Immediate Actions:**
 - Review your `package.json` and `package-lock.json` files for any of the affected packages
 - Update to verified clean versions of any affected dependencies
 - Scan your systems for indicators of compromise
 - Check cryptocurrency wallet transactions during the exposure window (13:16-15:15 UTC, September 8, 2025)
2. **Ongoing Security Measures:**
 - Implement NPM audit in your CI/CD pipeline
 - Use package lock files to ensure dependency integrity
 - Monitor security advisories for JavaScript ecosystem threats
 - Consider using security scanning tools for supply chain monitoring
 - Enable 2FA with hardware keys for all NPM and GitHub accounts
3. **Best Practices:**
 - Use `npm ci` instead of `npm install` to enforce lockfile integrity

- Pin package versions using overrides in package.json
- Audit dependencies regularly with tools like npm audit, Snyk, or Socket.dev
- Review lockfile changes in pull requests
- Mirror critical dependencies internally
- Implement proper access controls for package management

Timeline of Our Response

- **September 8, 2025:** Initial awareness of the attack through security community alerts
- **September 8, 2025:** Comprehensive dependency audit initiated immediately
- **September 24, 2025:** Security assessment completed - confirmed no affected packages in use
- **September 24, 2025:** This security notice published

Contact Information

For security-related inquiries regarding this notice: - **Security Team:** [security@company.com] - **General Support:** [support@company.com] - **Emergency Contact:** [emergency-security@company.com]

Additional Resources

- Endor Labs Analysis: <https://www.endorlabs.com/learn/major-supply-chain-attack-compromises-popular-npm-packages-including-chalk-and-debug>
- Check Point Security Blog: <https://blog.checkpoint.com/crypto/the-great-npm-heist-september-2025/>
- NPM Security Advisory: [NPM official response]
- Wiz Security Analysis: <https://www.wiz.io/blog/widespread-npm-supply-chain-attack-breaking-down-impact-scope-across-debug-chalk>
- Socket.dev Technical Analysis: <https://socket.dev/blog/npm-author-qix-compromised-in-major-supply-chain-attack>
- Company Security Policies: [Internal link]
- Incident Response Procedures: [Internal link]

References

- Endor Labs Analysis: <https://www.endorlabs.com/learn/major-supply-chain-attack-compromises-popular-npm-packages-including-chalk-and-debug>
- Check Point Security Blog: <https://blog.checkpoint.com/crypto/the-great-npm-heist-september-2025/>
- Wiz Security Analysis: <https://www.wiz.io/blog/widespread-npm-supply-chain-attack-breaking-down-impact-scope-across-debug-chalk>

- Socket.dev Technical Analysis: <https://socket.dev/blog/npm-author-qix-compromised-in-major-supply-chain-attack>
- Palo Alto Networks: <https://www.paloaltonetworks.com/blog/cloud-security/npm-supply-chain-attack/>
- Security Alliance Report: <https://www.securityalliance.org/news/2025-09-npm-supply-chain>

Document Classification: Public
Next Review Date: October 24, 2025
Approved by: [Security Team Lead]
Distribution: All Stakeholders

This notice will be updated as additional information becomes available.